ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider EcoStruxure Control Expert (engineering software for Modicon M340/M580) · Component type: **Software Application (SAR) - PLC/PAC engineering software** · Target SL = SL 3

Where to work	**EcoStruxure Control Expert** on a Windows host: **Tools › Security Editor** (user profiles + access rights - the tool RBAC; policy in the standalone Security Editor); **Project Settings** (application password, program protection); **File-encryption** + **data-storage** passwords (.STU/.STA/.ZEF); the **Certificate Whitelist** for secure engineering links (M580). Installer from Schneider (signed).
Ports / paths	Talks to controllers over **Modbus/UMAS TCP 502** (or HTTPS in M580 Enforced mode); project files **.STU (open) / .STA (archive) / .ZEF (export)**; the Security Editor policy is stored per install/host. Runs on Windows - harden the host + patch Control Expert (SEVD advisories, incl. project-file parsing CVEs).
Notes	SAR - Schneider EcoStruxure Control Expert (Unity Pro successor) for Modicon M340/M580/Momentum/Quantum. The **Security Editor** is the tool RBAC; project protection is via the application/file/data-storage passwords. Confirm the Control Expert version and that it is patched (several project-file parsing CVEs). Assess the target controller separately (M340 / M580 sheets).
How to read	Each row = native step-by-step (Security Editor / Project Settings) + command-level external-tool steps. Default read-only (open the .STU read-only, review the Security Editor policy). Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the Control Expert project (.STU) and archived application (.STA) plus an .XEF/.ZEF export, the section/application protection settings, and the logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Enable the **Security Editor** (Tools › Security Editor) so Control Expert requires a per-user logon with a profile, and set the project **application password** (Project Settings / program protection) so opening/modifying a project requires it. Without the Security Editor, Control Expert runs unauthenticated - do not accept that at SL-3. **Test:** launch Control Expert / open the .STU without credentials -> a Security-Editor logon + application password are required. **Ext. tools:** Control Expert (Security Editor enabled + user list); confirm the application password is set.	Security Editor enforces per-user logon; application password required; no unauthenticated use.	
SR/CR 1.2	Software process / device identification	Confirm the target controller identity (IP/Modbus address, CPU serial) and that only intended controllers are addressed; where M580 secure mode/IPsec is used, the link is authenticated. **Ext. tools:** Control Expert (device address); `nmap --script modbus-discover -p 502 <plc>`; Wireshark `modbus`.	Target controller identity confirmed; secured link where supported.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.3	Account management	In the **Security Editor** manage user profiles/accounts (create/modify/disable), assign least-privilege profiles, remove defaults, no shared logins. **Ext. tools:** Control Expert (Security Editor user/profile export); credential-custody record.	Named least-privilege profiles; defaults removed; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers in the Security Editor; no reuse; each engineer distinct. **Ext. tools:** Control Expert (Security Editor user list).	Unique user identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Confirm the **Security-Editor password policy**, the **application password**, the **file-encryption password** (.STU/.STA/.ZEF), and the **data-storage password** (IEEE 1686) are set and strong; change all defaults; store keys in the vault. **Ext. tools:** Control Expert (Security Editor policy + password review).	Strong Security-Editor / application / file / data-storage passwords; defaults changed.	
SR 1.6	Wireless access management	**N/A.** Engineering software with no wireless interface. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	For secure engineering to M580 (HTTPS/IPsec) confirm CA-signed certificates and the Security-Editor **Certificate Whitelist** (only whitelisted engineering clients connect); strong keys; defaults replaced. For M340 (no TLS) this is N/A at the link - compensate with segmentation. **Ext. tools:** Control Expert (Certificate Whitelist); `openssl s_client -connect <plc>:443` (M580).	CA-signed certs + Certificate Whitelist for secure engineering (M580); N/A/compensating for M340.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the Security-Editor logon and password prompts mask entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The Security Editor has **limited native lockout**; verify what exists and compensate with host/AD controls where the Security Editor is Windows-linked, plus segmentation. **Ext. tools:** Characterize behavior (authorized); host/AD lockout for linked accounts.	Lockout where available; otherwise Partial + compensating.	Known limitation.
SR/CR 1.12	System use notification	No Control Expert banner; enforce the approved use notice on the engineering-workstation host (GPO). **Ext. tools:** Host `gpresult /h gp.html`.	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the engineering host + controllers are in the trusted OT zone; remote engineering via VPN/jump host; Modbus/UMAS not exposed to untrusted networks. **Ext. tools:** `nmap -Pn -p 502,443 <plc>` from the untrusted side (expect filtered); firewall review.	Engineering access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	In the **Security Editor** confirm per-profile **access rights** (read / modify / debug / adjust / configure / security) follow least privilege. A read-only profile cannot download or change the configuration. **Test:** as a read-only profile, attempt a download/config change -> denied. **Ext. tools:** Control Expert (access-rights review); attempt a privileged action as a read-only profile.	Least privilege enforced per access right; privileged actions denied.	
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the engineering laptop and removable media (OS device-control); only authorized .STU/.STA projects and firmware loaded. **Ext. tools:** Host removable-media GPO; project/firmware provenance.	Portable/engineering media controlled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/SAR 2.4	Mobile code	Control mobile/embedded code: restrict any DTMs/add-ons and scripting to trusted, required, signed items; only the signed Control Expert + verified DTM library installed. **Ext. tools:** Installed DTM/add-on review; verify installer signatures.	Only signed/required components/DTMs; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; Control Expert re-auth via the Security Editor. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	Confirm online (UMAS) connections can be closed and the controller bounds concurrent programming connections; the application-password reservation prevents conflicting simultaneous edits. **Ext. tools:** Control Expert (connection/reservation review); Wireshark (session).	Sessions terminable; concurrent programming bounded.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm engineering actions are audited: Control Expert project events / change tracking record who modified with the Security-Editor user; for M580, on-controller Syslog captures downloads; forward to the SIEM/AssetCentre-equivalent. **Test:** download a change -> a change/audit record with the Security-Editor user + time. **Ext. tools:** Control Expert (change/audit records); M580 Syslog; SIEM.	Downloads/edits attributable to a Security-Editor user; events forwarded.	
SR/CR 2.9	Audit storage capacity	Confirm audit logs are sized or offloaded to the SIEM (and M580 Syslog retained), with alerting on collection failure. **Ext. tools:** SIEM/Syslog retention + source-silent alert.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the host + controller are NTP-synced so audit timestamps are accurate and correlate. **Ext. tools:** `w32tm /query /status`; controller time; Wireshark `ntp`.	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	For M580 use Enforced/Secured mode + IPsec/HTTPS so engineering comms are authenticated/encrypted; for M340 (no TLS) contain Modbus/UMAS in a segmented zone. Avoid cleartext UMAS across zone boundaries. **Ext. tools:** Wireshark `modbus || tls || esp`; `testssl.sh https://<plc>` (M580).	Engineering comms secured (M580) or contained/segmented (M340).	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the Schneider-**signed** Control Expert (verify the installer signature / download from Schneider); host anti-malware with exclusions; restrict install/upgrade to admins. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV; installed-version review.	Signed software validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: Security Editor enabled + policy, application/file/data-storage passwords, Certificate Whitelist (M580), and patch level, against the hardening baseline; compare the .STU. **Ext. tools:** Control Expert (settings vs baseline .STU); version check.	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the project: application + file-encryption + data-storage passwords; archive the encrypted .STA and use change detection; baseline/hash the project. **Test:** attempt to open the encrypted .STA without the file-encryption password -> blocked. **Ext. tools:** Control Expert (open encrypted .STA test); `certutil -hashfile proj.STA SHA256` for drift.	Project encrypted + password-protected; integrity baselined; change detected.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.5	Input validation	Patch known Control Expert **project-file parsing CVEs** and confirm the tool handles malformed project files/CIP input. **ISOLATED:** test opening crafted project files on a lab host. **Ext. tools:** Nessus/OpenVAS for known CVEs; Schneider SEVD cross-check; ISOLATED malformed-project test.	Known CVEs patched; malformed input handled safely.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors are handled gracefully without leaking sensitive info (no plaintext secrets in logs/crash dumps). **Ext. tools:** Control Expert / host event-log review.	Graceful error handling; no info leak.	
SR/CR 3.8	Session integrity	Where M580 secure mode/IPsec is applied, online sessions are integrity-protected; the application password protects UMAS integrity on M340 engineering links. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected on secured links; contained otherwise.	
SR/CR 3.9	Protection of audit information	Protect the audit/change store + transport and restrict who can read/clear it (Security-Editor rights + host ACLs); for M580 protect the Syslog transport. **Ext. tools:** Audit-store access review; Syslog transport (M580).	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the engineering host, remove .STU/.STA/.ZEF projects, passwords/keys, certificates, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** grep for secrets; confirm projects/keys removed; BitLocker status.	Projects/keys/certs purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm the file-encryption + data-storage passwords protect projects at rest, and M580 HTTPS/IPsec use strong parameters; disable weak/legacy protocols. **Ext. tools:** Control Expert (encryption set); `testssl.sh https://<plc>` (M580).	Projects encrypted at rest; modern comms crypto (M580); weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the engineering host + controllers sit in a segmented cell/OT zone behind a firewall; only required Modbus/UMAS/HTTPS flows cross; remote engineering via a jump host; no flat convergence with IT. **Ext. tools:** `nmap -p 502,443 <plc>` per zone; firewall rule review.	Engineering + controllers in a segmented zone; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Engineering software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate projects/controllers and least-privilege Security-Editor profiles per area; do not co-mingle unrelated criticality in one project. **Ext. tools:** Security-Editor profile/area segregation; project topology review.	Projects/areas partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm Control Expert change/audit records (and M580 Syslog) are readable/exportable by authorized staff and forwarded to the SIEM; passive OT IDS on the cell for Modbus/UMAS anomalies. **Ext. tools:** Control Expert export; M580 Syslog; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	The engineering tool is not a runtime service, but confirm the host is resourced/hardened and controller programming connections are bounded so a flood cannot deny engineering access; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; controller connection-limit review.	Host/connection resources bounded; engineering access available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the encrypted .STU/.STA projects, passwords/keys, and Security-Editor policy are backed up (versioned, offline) and a restore/rebuild is tested. **Ext. tools:** Backup repository; restore + validate on a lab host/controller.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: enable the Security Editor, set the application/file/data-storage passwords, install only required DTMs/add-ons, keep Control Expert patched, and remove sample projects. **Ext. tools:** Control Expert config review; installed-DTM review; version vs current.	Least functionality; project protection applied; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the Control Expert version, installed DTMs/add-ons, and the OS so vulnerabilities track against Schneider SEVD / CISA advisories. **Ext. tools:** Control Expert About / installed components; Schneider SEVD feed.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
EcoStruxure Control Expert	Native RBAC & project review (all FRs)	Tools › Security Editor (profiles/access rights/policy); Project Settings (application password); file-encryption + data-storage passwords; Certificate Whitelist (M580); change/audit records. Open the .STU read-only; export as the baseline.	Read/authorized project copy.

Tool / method	Verifies	How to use — steps / example	Constraints
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from Schneider.	Read-only.
nmap	Controller/service exposure & segmentation (1.13, 3.1, 5.x)	`nmap --script modbus-discover -p 502 <plc>`; `nmap -p 502,443 <plc>`; scan per zone.	Read-only; authorized.
Wireshark	Comms integrity & session (3.1, 3.8, 4.3)	Filter `modbus || tls || esp`; confirm IPsec/HTTPS (M580) or contained cleartext UMAS (M340).	Passive; SPAN/tap only.
testssl.sh / openssl	TLS to M580 (1.8, 4.3)	`testssl.sh https://<plc>` / `openssl s_client -connect <plc>:443` for secure engineering.	Read-only.
Nessus / OpenVAS + Schneider SEVD	CVE scan incl. project-file parsing (3.5, 7.8)	Scan the engineering host for known Control Expert CVEs; cross-check Schneider SEVD advisories.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.